NoteMD — Technical Architecture & Data Protection Evidence

Prepared: 26 August 2026 · **Revised:** 15 October 2026 **Purpose:** Evidence pack for DPIA, DSPT, DTAC and DCB0129 clinical safety work. **Scope:** Production configuration as committed. Items marked **(B)** are stated from configuration and need confirming against the live dashboards.

> *This is a technical review by the development team. It is not legal advice and does not itself constitute a DPIA. A DPO must sign off the lawful basis, Article 9 condition, and transfer assessments.*

Status key

	MEANING
A	Implemented and tested
B	Implemented, requires verification against live config
C	Not yet implemented
D	Requires action by NoteMD/provider, not development

1. System architecture and data flow

1.1 Components

LAYER	TECHNOLOGY	REGION
Frontend	React 18 / TypeScript SPA, static bundle	Render **(B — region to confirm)**
Authentication	Supabase Auth (GoTrue), JWT	`eu-west-1` Ireland
Backend/API	Supabase Edge Functions (Deno), 11 functions	`eu-west-1` Ireland
Database	Supabase PostgreSQL 15	`eu-west-1` Ireland
Audio storage	Supabase Storage, private bucket `audio-recordings`	`eu-west-1` Ireland
Context document storage	Supabase Storage, private bucket `context-documents`	`eu-west-1` Ireland **(A — verified)**
Real-time transcription — primary	AssemblyAI `universal-3-5-pro`, EU data zone	`streaming.eu.assemblyai.com` **(A — verified 14 Oct)**
Real-time transcription — fallback	Deepgram `nova-3`	`eu-central-1` Frankfurt **(A — verified 14 Oct)**
Enhanced dictation transcription	Azure OpenAI `gpt-4o-transcribe`	**France Central (A — verified)**
Letter generation	Azure OpenAI `gpt-4o`	**France Central (A — verified)**
Context document summarisation	Azure OpenAI `gpt-4o` (same deployment)	**France Central (A — verified)**
Email delivery	Azure Communication Services	**United Kingdom (A — verified)**
Billing	Stripe	Global — no patient data

All patient data now processes within the EEA or the UK. The August version of this document recorded OpenAI's global endpoint as the one route out and the highest item on the risk register; it was replaced on 5 October 2026. The legacy Google Cloud ASR service has been decommissioned.

Regions marked verified were read from the **provider's own response headers** (`x-ms-region` for Azure) or confirmed by opening a real session against the endpoint, not inferred from configuration.

1.2 Primary data flow — consultation

```
Clinician browser
  |
  |-- (1) Sign in ------------------> Supabase Auth (eu-west-1)  -> JWT
  |
  |-- (2) Microphone capture (local, in memory)
  |
  |-- (0) Optional: consultation context (see 1.5)
  |
  |-- (3) Request session -----------> Edge Fn streaming-session (eu-west-1)
  |                                    returns a short-lived credential, the
  |                                    complete EU endpoint URL, and a second
  |                                    descriptor for the fallback vendor
  |
  |-- (4) Audio stream -------------> AssemblyAI wss streaming.eu.assemblyai.com
  |         (direct browser -> vendor)  (EU data zone)
  |                                    <- interim + final transcript
  |                                    falls back to Deepgram (eu-central-1)
  |                                    if the session will not open
  |
  |-- (5) Transcript autosave ------> Supabase Postgres (eu-west-1)
  |         every ~15s, draft status
  |
  |-- (6) Clinician reviews/edits transcript on screen
  |
  |-- (7) Generate letter ----------> Edge Fn generate-letter (eu-west-1)
  |         audio uploaded to Supabase Storage (eu-west-1)
  |                                    |
  |                                    |-- transcript + patient name
  |                                    |     (NHS number is tokenised)
  |                                    |     -> Azure OpenAI notemd-eu
  |                                    |        (France Central)
  |                                    |     <- generated letter
  |                                    |
  |                                    |-- letter persisted -> Postgres (eu-west-1)
  |
  |-- (8) Letter displayed to clinician
  |
  |-- (9) Optional: email ----------> Edge Fn send-letter-email
  |                                    -> Azure Communication Services (UK)
```

1.3 Primary data flow — dictation (Enhanced engine)

No streaming vendor is used. Audio is captured in segments, each uploaded to Supabase Storage and transcribed by Azure OpenAI, with text appended to the on-screen transcript. Letter generation then proceeds as step (7) above.

Segments are cut **at natural pauses** rather than on a fixed clock, with a ten second ceiling. Fixed-interval cutting sent the model long silent tails to account for, and transcription models of this family produce plausible invented text from silence rather than returning nothing — which concentrated fabrications at the end of recordings, where the tail was longest.

Three further controls apply to this path and are covered in the clinical safety section: microphone level monitoring with an on-screen warning, a silence gate that declines to send segments containing no speech, and server-side rejection of transcription output bearing the marks of having been generated from nothing.

1.5 Consultation context (added 9 October 2026)

Background a clinician assembles before a consultation — typed or dictated notes, and uploaded documents such as previous clinic letters.

Digital PDFs have their text extracted **in the browser**; the document never leaves the device as an image. Scanned PDFs have their pages rendered locally and read by the same Azure OpenAI deployment used for letters, so optical character recognition introduces **no additional sub-processor**.

Uploaded documents are the most directly identifying data in the system and follow the **audio** retention period rather than the transcript one. The resulting summary is reference material for the clinician; it informs letter generation only when the clinician explicitly opts in, which is off by default and recorded against each letter in the audit trail.

See `evidence/consultation-context.md`.

1.4 Transcript integrity control

Any transcript displayed on the review screen is marked authoritative and sent with `transcript_source: "client"`. The server will not re-run speech recognition over a reviewed transcript. This guarantees the letter is generated from exactly the words the clinician read and approved. **(A — unit tested across all mode/engine combinations.)**

---

2. Data inventory

DATA	STORED WHERE	RETENTION	DELETION
Patient audio	Supabase Storage, private bucket, `{user_id}/` prefix	**30 days**, per-clinician configurable	Automatic nightly purge `gdpr_purge_expired_audio()` **(A)**
Audio segments (dictation)	Same bucket, `{user_id}/segments/`	Same 30-day policy	Same purge **(B — confirm segments matched by purge query)**
Transcripts	Postgres `letters.transcript`	10 years default (NHS record retention)	Manual, or `gdpr_erase_user()` **(A)**
Generated letters	Postgres `letters.letter_content`	10 years default	As above **(A)**
Patient identifiers (name, NHS number)	Postgres `recordings` + `letters`	With parent record	Cascade on record delete **(A)**
Clinician profile	Postgres `profiles`	Life of account	`gdpr_erase_user()` **(A)**
Account/login	Supabase Auth `auth.users`	Life of account	Requires admin API call **(C)**
Session tokens	Browser `localStorage`	Until logout/expiry	Cleared on sign-out **(A)**
Crash-recovery snapshot (transcript + identifiers)	Browser `localStorage`, namespaced per user	24h max	Purged on sign-out **(A)**
IP / device	Supabase platform logs	Supabase default	Platform-managed **(B)**
Application logs	Supabase Edge Function logs	Supabase default	Platform-managed **(B)**
Processing audit log	Postgres `processing_audit_log`, append-only	Indefinite	Retained deliberately for accountability **(A)**
Backups	Supabase managed PITR/daily	Plan-dependent	**(B — confirm plan and window)**
Billing	Stripe (clinician name/email/payment only — **no patient data**)	Stripe policy	Stripe-managed **(D)**
Analytics/telemetry	**None** — no analytics SDK is present **(A — verified)**	n/a	n/a

3. Data residency

3.1 Confirmed

PROVIDER	REGION	EVIDENCE
Supabase (DB, storage, auth, functions)	`eu-west-1` Ireland	Project configuration **(A)**
AssemblyAI	EU data zone	In-app check opened a session against `streaming.eu.assemblyai.com`, 14 Oct 2026 **(A)**
Deepgram	`eu-central-1` Frankfurt	In-app check opened a session against `api.eu.deepgram.com`, 14 Oct 2026 **(A)**

3.2 Outstanding

PROVIDER	CURRENT	REQUIRED ACTION
Azure OpenAI	France Central	**(A)** Verified from the `x-ms-region` response header for both the transcription and letter deployments, 5 Oct 2026.
Azure Communication Services	United Kingdom	**(A)** Resource data location UK; delivery verified with SPF, DKIM and DMARC alignment.
Render	Unconfirmed	**(B)** Static frontend only — **no patient data at rest**. Move to Frankfurt for tidiness.
~~**MedASR / Cloud Run**~~	~~`us-east4` Virginia~~	**DECOMMISSIONED.** Removed from the estate, along with the Hugging Face model dependency it carried.
Google Fonts	Google CDN (US)	**(C)** See §5.3 — receives clinician IP addresses.

3.3 Can patient data leave the UK/EEA?

No. Until 5 October 2026 transcripts, patient identifiers and dictation audio were sent to a provider outside the EEA. They now go to Azure OpenAI in **France Central**, and live transcription to AssemblyAI's **EU data zone** or Deepgram's **Frankfurt** endpoint. Email delivery is in the **United Kingdom**. All storage at rest remains in **Ireland**.

There is no longer an outstanding residency gap. The sub-processors outside the UK/EEA are Stripe and Render, and neither receives patient data.

4. Data minimisation and retention

ARTEFACT	RULE	STATUS
Audio	Auto-deleted after 30 days (configurable 1–3650)	**A**
Transcripts / letters	Retained per NHS record retention	**A**
Audio after transcription	*Not* deleted immediately — retained for the window above	**D — policy decision**
Temporary files	None written to disk server-side; audio is streamed in memory	**A**
Browser storage	Purged on sign-out	**A**
Logs	Supabase platform retention	**B**
Backups	Deleted data may persist in backups until they roll off	**B**

The request states audio should ideally be deleted immediately after transcription. That is a one-line change to the retention default, but it removes the ability to regenerate a letter or audit a transcript against source audio. **This is a clinical-safety trade-off for the client to decide.**

5. Logging review

5.1 Fixed during this review

The `transcribe-chunk` function logged the first 80 characters of every transcript to server logs. It was unreferenced by the application but remained a deployed, authenticated endpoint. **Removed from the repository — it must also be deleted in the Supabase dashboard (D).**

5.2 Current state (A)

No function logs transcripts, letters or patient identifiers. Logging is limited to character counts, HTTP status codes, provider names and timings.

5.3 Residual findings (C)

1. **Third-party error bodies are logged.** Failed calls log up to 500 characters of the vendor's error response (`body.slice(0, 500)`). A vendor that echoes submitted content in an error could place clinical text in logs. Low likelihood, non-zero. *Recommend redaction before logging.*
2. **Google Fonts.** `index.html` loads fonts from Google's CDN, transmitting every clinician's IP address to Google in the US on each page load. Not patient data, but it is personal data, and a German court has found this unlawful without consent. *Recommend self-hosting the fonts — removes a US third party entirely.*

6. Authentication and access control

CONTROL	STATUS
Supabase Auth, email + password, bcrypt	**A**
JWT sessions, auto-refresh	**A**
RLS enabled on **all six** tables	**A — verified**
Per-user isolation via `auth.uid() = user_id` on every table	**A**
Storage isolation by `{user_id}/` folder prefix	**A**
Secretary delegated access, scoped via `get_my_clinician_id()`	**A**
Audit log readable only by its owner; no client write path	**A**
Password change (signed in)	**A**
Password reset ("forgot password")	**C — not implemented**
MFA	**C — not implemented.** Supabase supports TOTP; requires build work.
Account revocation	**B — via Supabase dashboard only, no in-app flow**
Session timeout / idle lock	**C**

6.1 Cross-user access evidence

Isolation is enforced in Postgres, not application code, so it cannot be bypassed by a malformed client request. Automated evidence currently covers browser-side isolation (`src/test/local-phi.test.ts` proves one clinician cannot read another's cached data). **Database-level cross-user tests against a live instance are (C)** and are the strongest single addition for DTAC evidence.

7. Encryption and secrets

CONTROL	STATUS
TLS 1.2+ on all connections (app, API, vendors)	**A**
Encryption at rest — database and storage	**A — Supabase platform (AES-256)**
Service-to-service auth: JWT (Supabase), bearer tokens (vendors), GCP identity token (Cloud Run)	**A**
Secrets held in Supabase Edge Function environment	**A**
No secret keys in frontend code	**A — verified.** Only the Supabase URL and the publishable anon key are shipped, which is their intended use; they grant nothing without a valid JWT and are constrained by RLS.
Streaming credential	Short-lived, minted server-side per session
Key rotation policy	**C**

8. Vendor detail

8.1 Microsoft Azure OpenAI — enhanced dictation, letters, document summaries

- **Resource:** `notemd-eu`, **France Central**
- **Endpoints:** `/openai/deployments/{deployment}/audio/transcriptions`, `/chat/completions`
- **Deployments:** `gpt-transcribe` (transcription), `gpt-4o` (letters and document summaries)
- **Data sent:** dictation audio; consultation transcripts; patient name; uploaded context documents and rendered page images; template prompts. **The NHS number is tokenised and never sent.**
- **Region verified** from the provider's own `x-ms-region` response header, not from configuration.
- **No biasing prompt is sent.** A clinical vocabulary prompt was removed on 21 October 2026: these models return the prompt as dictation when there is no speech, so a prompt listing drug names was the mechanism by which drug names were fabricated.

8.2 AssemblyAI — live transcription, primary

- **Product:** streaming API v3, model `universal-3-5-pro`, pinned explicitly
- **Endpoint:** `wss://streaming.eu.assemblyai.com` — **EU data zone**
- **Data sent:** consultation audio only. No patient identifiers.

- **Medical mode:** off, by the client's decision after testing
- **Training exclusion:** a property of the European data zone under vendor policy. There is **no per-request parameter** — unlike Deepgram below. We enforce it by refusing to issue a session for any other host.
- **Authentication:** short-lived token minted server-side, 120-second redemption window. No long-lived key reaches the browser.
- **Outstanding (D):** signed DPA and written confirmation of the training and retention position.

8.3 Deepgram — live transcription, automatic fallback

- **Product:** real-time streaming API (`/v1/listen`), model `nova-3` , `en-GB`
- **Endpoint:** `wss://api.eu.deepgram.com` — verified `eu-central-1` **(A)**
- **Data sent:** consultation audio only. No patient identifiers.
- **Training exclusion:** `mip_opt_out=true` on **every** request, enforced in code; the session endpoint refuses to issue a URL without it.
- **Used only** when AssemblyAI cannot open a session at the start of a consultation. Mid-consultation switching is deliberately not attempted.
- **Note:** the credential is accepted by the global endpoint too, so residency is enforced by configuration and by the browser's Content Security Policy rather than by the key. An EU-scoped key would make non-EU routing impossible even by misconfiguration. **(D — hardening)**

8.4 Microsoft Azure Communication Services — email

- **Data sent:** generated letters and/or transcripts, patient identifiers, recipient addresses
- **Region: United Kingdom** (resource data location)
- **Delivery:** verified with SPF, DKIM and DMARC alignment from `mail.notemd.co.uk`
- **Note:** Microsoft has announced the retirement of ACS Email as a product in September 2028. Not urgent, but it should be on the roadmap.

8.5 Stripe

Clinician name, email and payment details. **No patient data.** Card details go directly from the browser to Stripe Checkout — they never touch NoteMD systems.

8.6 Google (incidental)

- `oauth2.googleapis.com` — service-account token exchange for Cloud Run. No patient data.
- `dns.google` — region lookup in the diagnostics function. Hostnames only.
- `fonts.googleapis.com` — see §5.3.

---

9. Data subject rights

REQUIREMENT	MECHANISM	STATUS
Locate a user's data	`gdpr_export_user()` returns profile, recordings, letters, templates, audit log as JSON	**A**
Export	Same function; Article 15/20	**A**
Delete clinical data	`gdpr_erase_user()` — letters, recordings, templates and storage objects	**A**
Delete audio files	Included above — storage objects removed by `{user_id}/` prefix	**A**
Propagation	Foreign keys cascade; storage deleted in the same transaction	**A**
Delete the auth account	**C — requires Supabase admin API; no in-app flow**	
Backups	Deleted data persists in backups until they roll off **(B)**	
Per-*patient* deletion	**C.** Current tooling is per-*user*. Deleting one patient's records requires manual SQL. **This is likely to be raised in a DPIA** and is worth building.	

Both functions write to the audit log, recording that the action occurred without copying the erased content.

10. Audit trail

`processing_audit_log` is append-only (no client INSERT/UPDATE/DELETE policy; writes come from the service role). Readable only by the subject.

EVENT	STATUS
Data export	**A**
Data erasure	**A**
Audio purged by retention	**A**
Login / logout	**C — available in Supabase Auth logs, not the application trail**
Record create/access/modify/delete	**C**
Transcript creation / letter generation	**C**
Export / download by clinician	**C**
Administrative access	**C**

Assessment: the table and its guarantees exist; event coverage is thin. Extending it to the events above is straightforward and is a likely DSPT requirement.

---

11. Browser and local storage

ITEM	STATUS
Recovery snapshot namespaced per user	**A**
All PHI purged on sign-out (including other users' residue)	**A**
Legacy un-namespaced key cleaned up	**A**
Session tokens cleared on sign-out	**A — Supabase client**
IndexedDB	**A — not used**
Cookies	**A — none set by the application**
Temporary audio	**A — held in memory only; released on discard/navigation**
Downloaded files	**B — letters copied to clipboard or emailed; no file download implemented**
Browser cache	**B — static assets only; no API responses cached**

Covered by automated tests, including one proving a second clinician on a shared workstation cannot read the first clinician's cached data.

---

12. Security testing

	STATUS
Automated test suite	**A — 102 tests**
Engine routing / transcript integrity	**A**
Browser PHI isolation	**A**
Schema/constraint conformance	**A**
Edge function CORS hygiene	**A**
Cross-user access (IDOR) against a live database	**C**
Dependency vulnerability scanning in CI	**C**
Independent penetration test	**D — must be commissioned**

13. Backup and recovery (B — all items to confirm against the Supabase plan)

Backups are managed by Supabase: daily backups on all plans, with point-in-time recovery on Pro and above. They inherit the project region (`eu-west-1`) and platform encryption at rest. Access is limited to project administrators.

To confirm: current plan, backup retention window, whether PITR is enabled, restoration procedure, and how long erased patient data persists in backups — the last of these is explicitly asked for in a DPIA.

14. Production / test separation

	STATUS
Single Supabase project (production)	**B**
No staging project	**C**
Local development uses the production Supabase project	**C — risk**
Real patient data copied to development	**A — no export/seed tooling exists**

Finding: there is no separate staging environment, so development points at production. No patient data has been copied out, but a development error could affect production data. **Recommend a separate staging project (C).**

15. Summary of outstanding actions

Revised 21 October 2026. The August version of this section listed MFA, password reset, a staging environment, the expanded audit trail, cross-user testing and per-patient handling as outstanding development work. All are implemented; they are recorded as completed below rather than deleted, so the history of the assurance work is legible.

Completed since August 2026

	EVIDENCE
Patient data no longer leaves the EEA or the UK	`evidence/azure-openai-cutover.md`, `evidence/assemblyai-residency.md`
Multi-factor authentication (TOTP), enforced at the route level	`src/components/TwoFactorSettings.tsx`, `MfaChallenge.tsx`, `ProtectedRoute.tsx`
Password reset flow	`src/pages/ResetPassword.tsx`; audited
Separate staging environment with synthetic data	`src/lib/environment.ts`; local development targets staging by default
Expanded audit trail — 38 distinct actions	`20260916090000_expanded_audit_trail.sql`
Cross-user / IDOR testing against a live database	`evidence/idor-results.md`; 26 integration tests
Per-patient data location and deletion	`20260828120000_per_patient_data_requests.sql`
Privileged profile columns locked against self-assignment	`20260917100000_lock_privileged_profile_columns.sql`
Rate limiting on endpoints that cost money or send mail	`20260917160000_rate_limiting.sql`
Third-party error bodies redacted before logging	`evidence/log-redaction-regression.md`
Backup configuration and a documented restore test	`evidence/backup-configuration.md`, `evidence/recovery-test.md`
Security headers and a strict CSP, verified in production	`evidence/security-headers.md`
MedASR / Cloud Run service decommissioned	Removes a US processor and the Hugging Face dependency

D — for NoteMD/providers (blocking)

1. **Signed DPA with AssemblyAI**, plus written confirmation of the training and retention position.
2. **Deepgram** — written confirmation of retention; request an EU-scoped key.
3. **Commission the independent penetration test** — see `PENTEST-PACK.md`.
4. Retrieve and file dated DPA copies for all current sub-processors.
5. **DPO sign-off** on the lawful basis, the Article 9 condition, and the France Central processing decision.
6. **Confirm the Render hosting region** — see §15.1.

C — development work, prioritised

1. Retire the superseded `deepgram-token` function, now replaced by `streaming-session`.
2. Dependency scanning in CI.
3. Self-host fonts (removes Google as a recipient of clinician IP addresses).
4. In-app account deletion.
5. Point-in-time recovery is **not enabled**; the recovery point objective is therefore up to 24 hours. Enabling it is a plan-level decision.

15.1 Render region — not determinable externally

This has been carried as "to be confirmed" since August and cannot be closed from outside the account. The live site is served through Cloudflare, so response headers show the **edge** point of presence (London, from a UK request) rather than the Render origin region — a distinction worth stating, because the header looks like an answer and is not one.

It must be read from **Render Dashboard → the static site → Settings → Region**.

Lower stakes than the other entries: Render serves the static bundle only and receives no patient data. Its access logs may contain clinician IP addresses.

Appendix — headline risks

1. **OpenAI transfer.** Patient data leaves the EEA and may be retained for 30 days. *Until ZDR and the EU project are enabled, use synthetic or anonymised data for pilots.*
2. **No per-patient deletion.** Erasure is per-clinician-account.
3. **No MFA.** For a system holding special category data this will be queried.
4. **Thin audit trail.** Structure is sound; event coverage is not.
5. **No staging separation.** Development operates against production.